MCP-Lock: Pinning Provenance and Tool Definitions for Coding-Agent MCP Servers

Aakash
Department of Computer Science and Engineering (Data Science)
SRM Institute of Science and Technology
gsaakash05@gmail.com

***Abstract*—Coding agents launch Model Context Protocol (MCP) servers with unpinned commands such as `npx -y pkg`, so every start may fetch a new version whose code and whose tool descriptions, which go straight into the model's context, have never been reviewed. We measure this exposure and build a defence. A census of 2,000 sampled MCP packages finds that 36.5% [34.5, 38.7] changed the tools they advertise within 90 days, and that 97.0% of tool changes carry no provenance, publisher, maintainer or install-script signal. We present MCP-Lock, a lockfile that pins version, archive digest, build identity, publisher, install scripts and a canonical hash of the tool definitions, and a pre-launch gate that compares every launch against it. In a pre-registered evaluation against the closest prior gate, MCP-Lock detects 39.8% of 490 real attacks versus 19.6% (exact McNemar $p = 3.2 \times 10^{-30}$), at a false-block rate of 33.4% versus 32.9% on 8,180 benign upgrades. The gain comes almost entirely from install-script diffs. An adaptive attacker who knows every check gets past the frozen gate in 7 of 12 attacks; five exploratory hardening switches close all but two, at costs that range from no benign upgrades newly blocked to more than a third of them.**

***Index Terms*—software supply chain, Model Context Protocol, coding agents, provenance, lockfiles, pre-registration**

I. Introduction

An MCP server gives a language-model agent its tools. Coding-agent harnesses start most of them from package registries with a runner command: `npx -y @scope/server`, `uvx server`. Kapner et al. found unpinned MCP declarations in 9.8% of 2,660 agent setups [1]. An unpinned launch resolves to whatever version is latest at that moment, so the code that runs, and the tool descriptions the model reads as instructions, can change between two sessions without any user action. Tool descriptions are an injection channel [2], and a server that changes them after it has been approved is the "rug pull" of the MCP threat literature [2], [3].

Existing pre-install checks do not look at this layer. The hook of Bagmar and Saraf [4] checks names, sources and age before `pip install`; registry provenance (SLSA [5], Sigstore [6], PEP 740 [7]) says who built an archive, not what tools it advertises; and the public MCP registry does not version tool definitions at all [8].

We ask three questions. **RQ1:** how often do MCP servers change their tool definitions, and do metadata signals reveal those changes? **RQ2:** does pinning provenance and tool definitions catch more real attacks than the existing gate, and at what cost? **RQ3:** what does an attacker who knows every check do, and what would stop them?

Contributions. (i) A census of MCP packages on npm and PyPI: metadata for all 15,272 eligible packages and statically extracted tool definitions for a stratified sample of 2,000 (Section III). (ii) MCP-Lock, a lockfile format and a gate that never executes package code (Section IV). (iii) A pre-registered evaluation against the closest prior gate on real malicious versions, synthetic rug pulls and benign upgrades, with a kill rule fixed in advance (Section V). (iv) An adaptive-attacker study with five hardening switches, each reported with its cost on benign upgrades (Section VI). Code, data and the registration are public (Section X).

II. Background and Threat Model

MCP. A server exposes tools; the client sends `tools/list` and receives, for each tool, a name, a description and an input schema, which it places in the model's context [9]. The list may change at run time, signalled by `notifications/tools/list_changed`. Security surveys catalogue tool poisoning, rug pulls and malicious servers [3], [10].

Registry provenance. npm can attach a SLSA provenance attestation, signed through Sigstore, that names the source repository, workflow and builder of a release [5], [6], [11]; PyPI offers the same through PEP 740 [7]. npm also records the publishing account and lifecycle scripts, which run at install time. Hijacked maintainer accounts and malicious install scripts are recurring attack patterns [12]–[15]; the 2025 Shai-Hulud worm combined both [16].

Threat model. A developer runs a coding agent with the MCP-Lock hook and a lockfile created while each server was benign. The attacker wants their code to run, or their text to reach the model, through a later launch. We consider five tiers: *T1* a squatter with a new package name; *T2* a thief of one maintainer's registry token; *T3* an attacker inside the release pipeline (workflow or merged commit); *T4* the package owner (malicious or sold); *T5* the owner of a dependency. Registry compromise, Sigstore forgery and attacks on the model itself are out of scope.

III. RQ1: Tool-Definition Drift

Frame and sample. We built a frame of MCP packages from the official MCP registry and from MCP configuration files on GitHub, and kept packages with at least two versions that resolve on their registry: 15,272 packages. From these we

drew a stratified random sample of 2,000 (by ecosystem and download tercile; fixed seed).

Extraction. For every selected version we fetched the archive, verified its registry digest, and extracted tool definitions statically from the source (registration calls in JavaScript/TypeScript, decorators and registrations in Python). Values that cannot be resolved without execution become an opaque marker, so a rebuild of unchanged source keeps its hash. The canonical hash is SHA-256 over the sorted, canonically serialised (name, description, input schema) triples. On 82 held-out servers that we started in a network-less container and queried with `tools/list`, tool-name precision was 92.2% and recall 78.0%: detected changes are real, and drift figures are lower bounds.

Results. 36.5% [34.5, 38.7] of sampled packages (731/2,000) changed their tool definitions within a 90-day window; among packages that shipped any release in the window, 59.0% [56.2, 61.7] did. Across release transitions with extractable tools on both sides, 33.7% (2,259/6,695) changed tools: 987 added a tool, 132 removed one, 1,374 changed a description and 1,157 an input schema. 33.7% of releases is therefore not a rare event that a reviewer can wait for.

Tool changes are also invisible to supply-chain metadata. 97.0% [96.3, 97.7] of tool-changing transitions had no provenance loss, publisher change, maintainer change or new install script on the same release, and none of these signals was more frequent on tool-changing than on other releases (Fisher's exact test, all $p \geq 0.25$). Over twelve months of all 228,044 releases in the frame, 3.65% of active npm packages lost build provenance at least once, 2.25% went from CI publishing to a human account, and 1.90% added an install script; only 25.9% (npm) and 46.4% (PyPI) of latest versions carry provenance. Metadata signals are rare, provenance is a minority property, and tool changes are frequent and orthogonal to both: a gate that wants to see tool changes has to look at the tools.

IV. MCP-Lock Design

Lockfile. `mcp-lock.json` sits next to the harness configuration. For each server it pins the exact version, the archive digest (npm SRI or PyPI SHA-256), the build identity (repository, workflow, builder) when provenance exists, the npm publisher and maintainers, the install scripts, and the canonical tool hash with the tool names. The continuity identity deliberately excludes ref and commit, which change on every honest release. A clean upgrade is a regenerated entry and a reviewable diff.

Gate. Before a command runs, the gate parses it (installs and runner launches, including `npx`, `pnpm dlx`, `bunx`, `uvx`, `pipx run`), resolves what the launch would fetch now, and compares it with the lock entry. It reads registry metadata, attestations and archives, and never executes package code. Table I lists the signals; S1 is our reimplementation of the Bagmar and Saraf checks [4]. A block denies the command; a warning asks the user. The gate runs as a Claude Code `PreToolUse` hook on shell commands and on writes to MCP configuration files, and fails closed to "ask" on internal errors.

TABLE I
GATE SIGNALS. S2–S5 COMPARE A LAUNCH AGAINST ITS LOCK ENTRY.

Signal	Fires when	Action
S1	name confusable, absent or younger than 30 days; untrusted source; hidden index; known-vulnerable pin	block
S2	provenance disappears, or a different repository / workflow / builder built the new version	block
S3	npm: published by hand after CI releases, or by a non-maintainer	warn
S4	new install-time lifecycle script (PyPI: sdist-only release after wheels)	block
S5	canonical tool hash differs (diff shown)	warn
gate	server not locked / same version, different digest	warn / block

TABLE II
CONFIRMATORY RESULTS (WILSON 95% CIS).

	S1-C	G
Detection on R	19.6% [16.3, 23.3]	39.8% [35.6, 44.2]
False blocks on B	32.9% [31.9, 34.0]	33.4% [32.3, 34.4]
Warnings on B	0	16.5% [15.7, 17.3]
H1	99 G-only vs. 0 S1-C-only cases; exact McNemar $p = 3.2 \times 10^{-30}$ (Holm 6.3×10^{-30})	
H2	false blocks +0.42 pp [0.28, 0.56]; $p = 1.2 \times 10^{-10}$	
Kill rule	99 added detections ≥ 2: not killed	

V. RQ2: Pre-Registered Evaluation

Design. Hypotheses, corpora, scoring and a kill rule were registered on OSF before any scored run, with the gate frozen at a tagged commit. **H1:** on real attacks, G (S1–S5) detects more cases than S1-C, the stronger reading of the baseline. **H2:** on benign upgrades, G's false-block rate differs from S1-C's. **Kill rule:** the method claim is withdrawn if S2–S5 add fewer than two detections while G's false-block rate is equal or worse. Detection is block or warn; H1 and H2 use exact McNemar tests [17] with Holm correction [18]; proportions carry Wilson 95% intervals [19]. Six deviations, all logged before the affected results, concern replay mechanics and corpus construction.

Corpora. R-B: 22 scenarios of the baseline paper. R-M: 468 real malicious npm/PyPI versions from OpenSSF and Datadog reports [20], [21], 368 hijacked existing packages (class C, locked at the last clean version) and 100 new or typosquatted ones (class N). R = R-B ∪ R-M, $n = 490$. R-S: synthetic rug pulls on a local registry (four classes × 10 servers, 10 controls), reported separately. B: 8,180 benign upgrades (6,695 MCP, 992 top npm, 493 top PyPI). Every case is replayed offline as of its publication time.

Results. Table II gives the confirmatory results: both hypotheses hold and the kill rule is not triggered. The ablation explains where the gain comes from. Removing S4 loses 96

TABLE III
EVASION MATRIX. G: FROZEN GATE; H: ALL HARDENING SWITCHES.

Case	Tier	Attack	G	H
E1	T1	new name, edit distance ≥ 2, older than 30 days	warn	warn
E2	T2	stolen token; lock has no provenance	allow	block
E3	T2	stolen token; lock has provenance	block	block
E4	T3	payload via the genuine release workflow	allow	allow
E5	T4	poisoned description built at run time	warn	block
E6a/b	T4	tools fetched from a URL; new / no new version	allow	block
E7	T4	poison in an input-schema field description	warn	block
E8a/b	T4	time-bomb tool / tool from a base64 blob	warn/allow	block
E9	T5	payload and tools in a caret-range dependency	allow	block
E10	T2/T4	extra file added to a locked PyPI release	allow	block
E11	any	22 command shapes (detected)	13/22	21/22

of G's detections, removing S5 2, S3 1 and S2 0. On hijacked packages (class C) G detects 31.5% [27.0, 36.4] against 4.6% for S1-C, mostly install scripts added by the 2025 worm campaigns [16]; on new names (class N) both detect 59.0% through the baseline's age rule. Provenance continuity (S2) added nothing on real attacks, for a structural reason: removed malicious versions leave no registry record, so S2 and S3 were evaluable on only 88 of 468 R-M cases, and only 13.6% of class-C locks had provenance to begin with.

On the synthetic rug pulls, G detects 40/40 and S1-C 0/40; S5 alone carries the two tool-definition classes, S4 the install-script class, and S2 and S3 each catch the stolen-token class. No control was flagged (0/10).

The cost is the review burden. G's false blocks barely move (34 more than S1-C), but S5 adds warnings on 16.5% of benign upgrades, essentially all in the MCP stratum, where honest servers change tools often (RQ1). Per added detection, G costs 0.34 extra false blocks and 13.6 extra warnings. The baseline's own 32.9% false-block rate comes from its 30-day age rule replayed at upgrade time (40.1% of MCP upgrades). Median gate latency is 0.99 s on a cold cache (p95 3.19 s; $n = 199$) and 0.05 s warm.

VI. RQ3: ADAPTIVE ATTACKER

Setup. For each tier we built the cheapest attack we could find against a gate whose checks, lock format and parser are known, as 12 packages on a local registry with inert payloads, plus 22 command-line variants of one attack (Table III). All runs use the frozen gate; nothing was published publicly or executed.

What evades. The frozen gate blocks 1 and warns on 4 of the 12 attacks; 7 pass. The pattern is systematic. Static extraction cannot see tools built at run time or fetched from a URL (E6, E8b), and a rug pull through a remote file needs

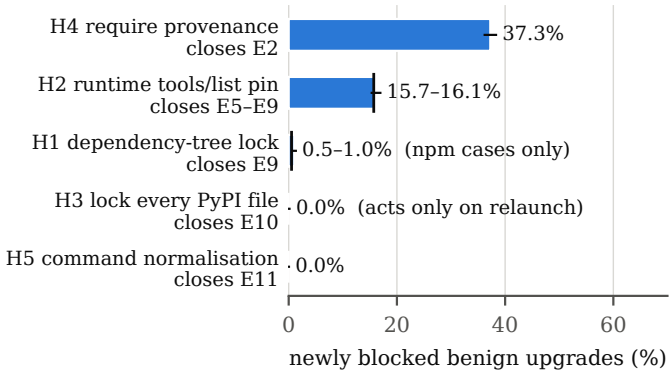


Fig. 1. Cost of each hardening switch: benign upgrades it would newly block on top of the frozen gate (bar: upper estimate with Wilson 95% CI; tick: lower estimate). H1 is measured on the 5,652 npm upgrades, H3 on PyPI.

no new version at all (E6b). Locking the top-level archive leaves dependencies free to move (E9). A stolen token defeats S2 and S3 whenever the lock never had provenance (E2), and the same-version check compares only the locked file (E10). Commands hidden behind `npm exec`, `sh -c` or a shell variable escape the parser. These attacks apply widely: 60.1% of benign locks have no provenance (E2), 21.7% of versions hide their tools from static extraction (E6/E8), and 93.9% of npm servers float their MCP SDK dependency (E9, a lower bound that counts one dependency). A payload shipped through the genuine release pipeline (E4) carries genuine provenance; no lock can tell it apart from an honest release.

Hardening (exploratory). We implemented five switches, off by default; with all off the gate is the frozen code, and a re-replay of every Phase-4 corpus is identical case by case. *H1* locks the resolved npm dependency tree and applies the S2–S4 rules to every dependency whose version changed. *H2* is a stdio proxy that pins the live `tools/list` per tool (trust on first use), rejects listings that add or change a tool, and refuses calls to unpinned tools; it checks every listing, so a time bomb is caught when it fires. *H3* locks every file of a PyPI release. *H4* requires provenance. *H5* normalises the evasive command shapes. With all five, 10 of 12 attacks block and 21 of 22 command shapes are caught; E1 still only warns and E4 passes.

Cost. Figure 1 shows that the switches split cleanly. H3 and H5 cost nothing on benign upgrades: H5 changes no decision (0/8,180), and H3 only acts when the locked version is relaunched, which no upgrade does; as an exposure measure, 0.47% of locked PyPI releases later gained a file. H1 adds blocks to 0.53%–1.03% of npm upgrades, depending on whether the lock was taken just before the upgrade or when the old version was released. A strict tree lock that blocks every dependency change, as `npm ci` would, blocks 12.3%–48.9% instead, so continuity rules rather than exact pins are what make dependency locking usable. H2 and H4 are expensive: H2 newly blocks 15.7%–16.1% of benign upgrades, all MCP servers that changed tools, and H4 37.3%. The live tool list of a historical version cannot be observed without running it, so

H2's benign cost assumes it equals the static extraction, and the 1,483 upgrades without statically visible tools are counted as costless.

VII. Discussion and Limitations

What the evidence supports. Pinning catches real attacks that the name-and-source checks miss, but the confirmed gain is an install-script diff (S4), a classic supply-chain signal rather than an MCP-specific one. Tool pinning (S5) is what catches MCP rug pulls, and it is necessary because metadata signals do not accompany tool changes (RQ1), yet it warns on 19.7% of honest MCP upgrades. Provenance continuity is sound but rarely applicable: most packages have none, and attackers who remove their versions take the evidence with them.

Limits of a lock. Every lock in this paper trusts the state at lock time and flags change. An attacker in the release pipeline (T3) produces change that is indistinguishable from an honest release, and a runtime pin can only compare against what was trusted first. Reviewing the diff remains the user's job; the gate makes the diff visible.

Threats to validity. Static extraction under-counts tools (recall 78.0%), so drift and S5 coverage are lower bounds. R-M contains only attacks that were caught and reported; attacks still undetected are absent by definition. Replay reconstructs metadata as of each case's time but cannot recover removed versions, which is why S2/S3 evaluability is low. Class C follows a mechanical rule (an earlier clean version exists) and may include attacker-owned packages with a benign first release. The adaptive attacks were built by the authors of the defence; the hardening results are exploratory and were not pre-registered, and H2's matrix verdicts use live tool lists written down from each attack's source rather than observed from running servers. Time of lock is unknown in practice, which is why H1 is reported as a range.

VIII. Related Work

MCP security. Surveys and taxonomies describe tool poisoning, rug pulls and malicious servers [3], [10], and practitioners described the rug-pull pattern early on [2]. Hasan et al. analyse the security and maintainability of open-source servers [22]. Closest to RQ1, Kraishan measures drift of the fields the MCP registry versions (descriptions, packages, endpoints) across 8,900 multi-version servers and notes that tool definitions are not versioned there [8]; we measure the tool definitions themselves from package archives, and build the client-side pinning that work recommends. Metere proposes signed admission and per-server tool allowlists for remote servers [23]; MCP-Lock instead needs no change to servers or registries.

Agent supply chains. Bagmar and Saraf weaponise setup instructions against coding agents and propose the pre-install hook we use as baseline [4]. Kapner et al. scan agent configurations and report unpinned MCP declarations [1]. Shan finds in a pre-registered audit that coding assistants almost never check trust signals before installing [24], which motivates a gate that checks on their behalf.

Package supply chains. Attack catalogues [12], [13] and ecosystem studies [14], [15] document account takeover and install-script abuse, the patterns behind S3 and S4. Sigstore [6], SLSA [5] and PEP 740 [7] make build identity verifiable; MCP-Lock uses that identity for continuity rather than for absolute trust.

IX. Conclusion

MCP servers change the tools they present to models often, and nothing in their metadata says so. A lock that pins archive, provenance, publisher, install scripts and tool definitions catches 99 real attacks that the existing gate misses, at a cost paid mostly in reviews of honest tool changes. Against an adaptive attacker, the frozen gate stops 5 of 12 attacks; dependency-tree locking, runtime tool pinning, file-level PyPI locking and command normalisation close most of the rest, and the price of each is now measured. Two gaps remain open for any lock-based defence: attacks shipped through the legitimate release pipeline, and the review fatigue of honest change.

X. Artifact Availability

Code, lockfile specification, replay bundles, results and logs: https://github.com/ftaakash/MCP-Lock. Pre-registration: https://osf.io/2amj3. Every number in this paper is generated from the result files by `paper/make_numbers.py`.

References

[1] B. Kapner, C. Soceanu, A. Petrunin, and H. Gartner, "Scanning the harness: Configuration exposures in AI coding-agent supply chains," arXiv:2609.07360v3, 2026.

[2] L. Beurer-Kellner and M. Fischer, "MCP security notification: Tool poisoning attacks," Invariant Labs blog, 1 Apr. 2025, https://invariantlabs.ai/blog/mcp-security-notification-tool-poisoning-attacks, 2025.

[3] X. Hou, Y. Zhao, S. Wang, and H. Wang, "Model Context Protocol (MCP): Landscape, security threats, and future research directions," arXiv:2503.23278, 2025.

[4] A. Bagmar and P. Saraf, "Setup complete, now you are compromised: Weaponizing setup instructions against AI coding agents," arXiv:2607.15143, 2026.

[5] SLSA, "SLSA provenance, version 1.0 (predicate type `https://slsa.dev/provenance/v1`)," https://slsa.dev/spec/v1.0/provenance, 2023.

[6] Z. Newman, J. S. Meyers, and S. Torres-Arias, "Sigstore: Software signing for everybody," in *Proc. ACM SIGSAC Conf. Computer and Communications Security (CCS)*, 2022, pp. 2353–2367.

[7] W. Woodruff, F. Tuesca, and D. Ingram, "PEP 740 – index support for digital attestations," https://peps.python.org/pep-0740/, 2024.

[8] O. Kraishan, "Same name, different server: A security census of silent drift in the Model Context Protocol ecosystem," arXiv:2609.14119, 2026.

[9] Model Context Protocol, "Specification (revision 2025-06-18): Tools," https://modelcontextprotocol.io/specification/2025-06-18/server/tools, 2025.

[10] W. Zhao, J. Liu, B. Ruan, S. Li, and Z. Liang, "When MCP servers attack: Taxonomy, feasibility, and mitigation," arXiv:2509.24272, 2025.

[11] npm, "Generating provenance statements," npm Docs, https://docs.npmjs.com/generating-provenance-statements, 2026.

[12] M. Ohm, H. Plate, A. Sykosch, and M. Meier, "Backstabber's knife collection: A review of open source software supply chain attacks," in *Proc. DIMVA*, ser. LNCS, 2020, pp. 23–43.

[13] P. Ladisa, H. Plate, M. Martinez, and O. Barais, "SoK: Taxonomy of attacks on open-source software supply chains," in *Proc. IEEE Symposium on Security and Privacy (SP)*, 2023, pp. 1509–1526.

[14] N. Zahan, T. Zimmermann, P. Godefroid, B. Murphy, C. Maddila, and L. Williams, "What are weak links in the npm supply chain?" in *Proc. 44th Int. Conf. Software Engineering: Software Engineering in Practice (ICSE-SEIP)*, 2022, pp. 331–340.
[15] M. Zimmermann, C.-A. Staicu, C. Tenny, and M. Pradel, "Small world with high risks: A study of security threats in the npm ecosystem," in *Proc. 28th USENIX Security Symposium*, 2019, pp. 995–1010.
[16] CISA, "Widespread supply chain compromise impacting npm ecosystem," Alert, 23 Sep. 2025, https://www.cisa.gov/news-events/alerts/2025/09/23/widespread-supply-chain-compromise-impacting-npm-ecosystem, 2025.
[17] Q. McNemar, "Note on the sampling error of the difference between correlated proportions or percentages," *Psychometrika*, vol. 12, pp. 153–157, 1947.
[18] S. Holm, "A simple sequentially rejective multiple test procedure," *Scandinavian J. Statistics*, vol. 6, no. 2, pp. 65–70, 1979.
[19] E. B. Wilson, "Probable inference, the law of succession, and statistical inference," *J. American Statistical Association*, vol. 22, no. 158, pp. 209–212, 1927.
[20] OpenSSF, "Malicious packages: Reports of malicious packages in open source repositories (OSV format)," https://github.com/ossf/malicious-packages, 2026.
[21] Datadog, "Malicious software packages dataset," https://github.com/DataDog/malicious-software-packages-dataset, 2026.
[22] M. M. Hasan, H. Li, E. Fallahzadeh, G. K. Rajbahadur, B. Adams, and A. E. Hassan, "Model Context Protocol (MCP) at first glance: Studying the security and maintainability of MCP servers," arXiv:2506.13538, 2025.
[23] A. Metere, "Attested tool-server admission: A security extension to the Model Context Protocol," arXiv:2605.24248, 2026.
[24] P. Shan, "Do AI coding assistants check before they install? A pre-registered demand-side audit of trust signals in the research software supply chain," arXiv:2609.07754, 2026.